

NISIR BANK S.C.

SETA Employee Training Portal
Security Education, Training & Awareness

SECURITY AWARENESS TRAINING GUIDE

Foundational Learning — Phishing & Social Engineering

For: All Nisir Bank Employees — Mandatory Pre-Inbox Access Training

Document Reference: NISIR-SETA-TRG-001 | Version: 1.0

Issued by: Security Operations Team | Nisir Bank S.C., Addis Ababa, Ethiopia

HOW TO USE THIS DOCUMENT

Read this training guide carefully from beginning to end. After completing the training content, you will be required to complete the Security Awareness Assessment at the end of this document. The assessment is automated on the Nisir Bank SETA Portal — your answers and score are recorded and used to standardize your security knowledge baseline before you begin working with the Internal Mail system.

This document is available as a downloadable resource on the Foundational Learning page of your SETA Portal.

Security Awareness: Phishing, Social Engineering & Safe Digital Behaviour

1. Why Security Awareness Matters at Nisir Bank

Nisir Bank S.C. is a licensed commercial bank operating under the directives of the National Bank of Ethiopia (NBE). As a financial institution, we hold sensitive customer data, process millions of birr in transactions daily, and operate critical digital infrastructure. This makes us — and every employee — a target for cybercriminals.

The most significant security threat facing Ethiopian banks today is not sophisticated technical hacking — it is human deception. Attackers know that the easiest way to break into a bank's systems is not to crack the technology, but to trick an employee into opening the door for them. This is why your awareness, judgment, and behaviour are the bank's most important security asset.

NBE Requirement: The National Bank of Ethiopia's Cybersecurity Training Directive 17/2024 requires all licensed banks to provide mandatory security awareness training to all staff. Completion of this training module is recorded in your permanent employee training record and may be requested during regulatory compliance audits.

 **KEY POINT:** Every employee at Nisir Bank — from tellers to management — is a target. Attackers do not discriminate by seniority or department. Your vigilance protects yourself, your colleagues, and every customer who trusts Nisir Bank with their money.

2. Understanding Phishing

2.1 What Is Phishing?

Phishing is a form of cyberattack in which an attacker sends deceptive communications — typically emails — designed to trick the recipient into revealing sensitive information, clicking a malicious link, downloading harmful software, or transferring funds. The term comes from the idea of 'fishing' for victims using bait.

In a banking context, phishing attacks typically target:

- Employee login credentials (Employee ID and password) to gain unauthorized access to bank systems
- Customer account information to facilitate financial fraud
- Internal banking procedures to authorize fraudulent transactions
- Network access to install malware that can compromise the entire bank's infrastructure

 **WARNING:** According to the NBE's 2023 Financial Sector Cybersecurity Report, phishing and social engineering attacks account for over 70% of successful security incidents in Ethiopian

financial institutions. You are the primary target — and the primary defence.

2.2 How Phishing Works — The Attack Sequence

Understanding how a phishing attack unfolds helps you recognize and stop it at every stage:

Stage	What the Attacker Does	How to Stop It Here
1	Sends a deceptive email impersonating a trusted source (IT, HR, regulator, colleague)	Check the sender email address domain — not just the display name
2	Creates urgency or fear to prevent careful thinking ('act now or lose access')	Slow down. Legitimate bank processes never require emergency actions via email links
3	Includes an inline link leading to a fake website or credential capture form	Hover over all inline links to check the actual URL before clicking
4	Captures credentials or installs malware when victim clicks or submits	Report suspicious emails before taking any action on them
5	Uses stolen credentials to access systems or escalate the attack	Report immediately if you accidentally clicked — the no-blame policy protects you

2.3 The Five Types of Phishing You Must Know

Type 1: Standard Phishing

Generic mass emails sent to thousands of targets simultaneously. These typically impersonate well-known institutions — banks, telecom companies, government bodies — and use generic greetings like 'Dear Customer' or 'Dear Employee.' While less sophisticated, they are still effective because they are sent at high volume.

Example: An email saying 'Dear Bank Employee, Your account has been compromised. Click here to secure it immediately' sent to thousands of email addresses simultaneously.

Type 2: Spear Phishing

Highly targeted attacks that use personal, organisational, or contextual details about the specific victim to appear legitimate. The attacker researches you first — learning your name, role, department, colleagues' names, and recent events — then crafts an email that feels personally relevant. This is the most common and dangerous type in banking environments.

Example: An email addressed to you by name, referencing your specific role and a recent training

session you attended, asking you to complete a follow-up step via an inline link.

 **KEY POINT:** Spear phishing is hard to detect precisely because it feels familiar and relevant. The personal details make you lower your guard. Remember: the presence of personal details in an email does NOT mean it is legitimate — it may mean the attacker has done their research.

Type 3: Internal Impersonation

Emails that appear to come from a trusted internal colleague — the IT Security Officer, HR Coordinator, your line manager, or even the CEO. The attacker uses a sender display name that matches a real staff member but uses a subtly different email domain. In your SETA Portal inbox, the sender's email address is displayed clearly under their name in the reading pane. Always check it.

Legitimate Sender	Impersonation Attempt
itsecurity@nisirbank.com	itsecurity@nisirbank-it.com
natnael.worku@nisirbank.com	natnael.worku@nisirbank-support.com
hr@nisirbank.com	hr@nisirbank.co
compliance@nisirbank.com	compliance@nisirbank-ethiopia.org

 **WARNING:** The sender DISPLAY NAME can say anything — 'Ato Biruk Alemu — IT Security' — but the actual email address domain reveals the truth. In your SETA Portal, the full email address is shown under the sender's name in the reading pane. Always check it before taking any action.

Type 4: Regulatory Impersonation

Emails appearing to come from regulatory or government bodies such as the National Bank of Ethiopia, the Ethiopian Banking Compliance Authority (EBCA), the Financial Intelligence Centre, or other official institutions. These exploits the authority and compliance obligations associated with regulatory bodies to create pressure to act immediately.

Example: An email claiming to be from the 'EBCA Compliance Monitoring Unit' requiring all bank employees to complete a mandatory staff awareness survey via an external link before a specific deadline or face compliance consequences.

Key fact: Legitimate regulatory communications to individual bank employees are always coordinated through Nisir Bank's Compliance Department first. They are never sent directly to individual staff members requiring immediate personal action via external links.

Type 5: Social and Informal Phishing

Attacks disguised as casual, social, or personal communications — staff event photos, team celebration announcements, competition results, or messages from apparent staff welfare groups. These exploit the reduced vigilance people apply to non-work content and often come from non-official email addresses (such as Gmail or Yahoo) not on the staff directory.

Example: An email with emoji in the subject line from 'staffassociation.nisir@gmail.com' inviting you to click a link to view photos from last week's staff team day. The sender is not on your official staff directory.

 **KEY POINT:** All official Nisir Bank staff communications — including social announcements and welfare updates — are sent from @nisirbank.com addresses or posted to the Community section of your SETA Portal. Any social or informal email with an inline link from a non-@nisirbank.com sender should be treated with suspicion.

3. Social Engineering Beyond Email

3.1 Pretexting

Pretexting is a social engineering attack conducted through direct communication — usually by phone — where the attacker creates a fabricated scenario (the 'pretext') to extract information or access. Common pretexts in banking include:

- Impersonating IT Support and claiming an urgent security issue requires your password
- Posing as an internal auditor who needs access to a colleague's workstation
- Claiming to be from HR and requesting personal employee information for a 'routine verification'
- Impersonating a senior manager who needs an urgent bank transfer processed

 **KEY POINT:** The defining characteristic of pretexting is the false scenario. The attacker needs you to believe the context is real before you will comply. Nisir Bank IT staff will NEVER ask for your password — by phone, email, or any other channel.

3.2 Baiting

Baiting attacks use physical media — typically USB drives — left in visible locations such as the bank's car park, reception area, or staff kitchen. The attacker labels the drive with an enticing description ('Salary Review 2025' or 'Staff Bonus List') hoping a curious employee will plug it into a bank computer.

 **WARNING:** Never plug any USB drive or portable storage device into a bank computer unless it has been provided and cleared by the IT Security team. This applies to all portable storage including USB drives, external hard disks, and memory cards.

3.3 Quid Pro Quo

Quid pro quo attacks offer something in exchange for information or access — for example, an attacker posing as a technical support agent who offers to help solve a computer problem in exchange for temporary access to your login credentials.

4. Warning Signs — Your Detection Checklist

Before clicking any inline link or taking any action on any email in your Nisir Bank SETA Portal inbox, run through this checklist:

✓	Warning Sign to Check
1	SENDER EMAIL DOMAIN: Is the email from an @nisirbank.com address? Check the full email address shown under the sender's name in the reading pane — not just the display name.
2	STAFF DIRECTORY: Is the sender on your staff directory (provided in your Onboarding Brief)? External senders not on the directory require verification before any action.
3	URL INSPECTION: If the email contains an inline link, hover your mouse over it. Does the URL displayed at the bottom of your browser match nisirbank.com? Any other domain is suspicious.
4	URGENCY AND THREATS: Does the email create artificial urgency or threaten negative consequences (account suspension, regulatory action, financial penalty) to pressure you into acting quickly?
5	CREDENTIAL REQUESTS: Does the email ask you to enter your Employee ID, password, or any other credentials via a link or form? This is never a legitimate request at Nisir Bank.
6	UNEXPECTED CONTENT: Did you expect this email? Unexpected requests — even from known senders — should be verified through a separate channel before action is taken.
7	EXTERNAL REGULATORY CLAIMS: Does the email claim to be from a regulatory body requiring direct action via an external link? These must always be verified through the Compliance Department.
8	TONE AND FORMAT: Does the email use an unusually casual tone, emoji, or language inconsistent with professional bank communications? Especially from a non-@nisirbank.com address?

5. The SETA Portal Inbox — Special Considerations

Your Nisir Bank SETA Portal inbox (accessible via the Inbox tab in the navigation bar) is the primary communication channel through which you receive messages from HR, IT Security, Compliance, Finance, and your branch. Understanding how legitimate emails are structured will help you identify fraudulent ones.

5.1 How to Read Your Inbox Safely

- When you open an email, always check the sender's full email address shown under their name in the reading pane — not just the display name shown in the inbox list.
- Legitimate Nisir Bank emails always come from @nisirbank.com addresses. The staff directory in your Onboarding Brief lists all verified senders.

- Many legitimate emails contain inline clickable links within the body text (shown as blue underlined text). This is a normal feature of the portal. Always hover over any inline link before clicking to verify the URL.
- Legitimate inline links in official emails lead to nisirbank.com pages — training modules, compliance documents, HR forms, or financial records — all within the portal.
- The Community page of your portal (accessible from the top navigation) includes a 'Report Suspicious Threat' button. You can also use this to report suspicious emails.

5.2 Inline Links — The Key Distinction

Because legitimate emails in your inbox DO contain inline links, you cannot use 'this email has a link' as a detection rule. You must evaluate each link on its own merits. The table below shows the difference:

Legitimate Inline Link	Phishing Inline Link
Leads to nisirbank.com when you hover	Leads to a different domain when you hover
Sent from a verified @nisirbank.com address	Sent from a non- @nisirbank.com address
Expected — relates to your current tasks	Unexpected — creates urgency or unusual requests
Takes you to portal training, HR, or compliance pages	Takes you to credential capture or external forms
Sender is on your staff directory	Sender is NOT on your staff directory

6. Customer Data Protection

As a Nisir Bank employee, you handle sensitive customer information in the course of your daily work. This includes customer names, account numbers, transaction histories, identity documents, and financial information. Protecting this data is both a legal obligation and a fundamental ethical responsibility.

- Never share customer account information via email in response to unsolicited requests, regardless of how the request is framed or who appears to be asking.
- All requests for customer data from external parties must be channelled through the Compliance Department and follow formal inter-bank data sharing protocols.
- Do not access customer accounts you are not authorised to access, even if you believe it is for a legitimate purpose.
- Do not store customer data on personal devices, external storage media, or any cloud service not approved by IT Security.
- If you accidentally expose or share customer data, report it immediately to itsecurity@nisirbank.com — the no-blame policy applies to good-faith reporting of data incidents as well.

7. Password Security

7.1 Password Requirements

Your SETA Portal password is the primary key to your employee account and all bank systems you are authorised to access. Nisir Bank requires:

- Minimum 10 characters in length
- At least one uppercase letter (A–Z)
- At least one lowercase letter (a–z)
- At least one number (0–9)
- At least one special character (@, #, \$, %, !, &)
- Must not contain your name, Employee ID (E-XXXXX format), job title, or department name
- Must not be a previously used password (last 5 passwords are blocked)
- Must be changed every 90 days — the system will prompt you

7.2 Password Protection

- Never share your password with anyone — including IT Security staff, supervisors, or colleagues — under any circumstances
- Change your password only through Account Settings inside the portal — never through an email link
- Never write your password on paper or store it in an unencrypted document on your computer
- Use a unique password for your Nisir Bank account — never reuse passwords from personal accounts
- Lock your workstation whenever you step away from your desk

 **WARNING:** You will NEVER receive a legitimate email asking you to click a link to update or verify your password. All password management is done through Account Settings inside the SETA Portal directly. Any email instructing you to change your password via a link is a phishing attack.

8. Reporting Security Incidents

Nisir Bank operates a no-blame reporting culture. If you suspect you have been targeted by a phishing attack, or if you accidentally clicked a suspicious link or entered information on a suspicious page, you must report it immediately. You will NOT face disciplinary action for good-faith reporting.

You can also use the 'Report Suspicious Threat' button on the Community page of your SETA Portal to report suspicious communications.

Contact	Details
IT Security Helpdesk	itsecurity@nisirbank.com Extension 2200
Compliance Department	compliance@nisirbank.com Extension 2201

Human Resources	hr@nisirbank.com Extension 2100
Community Portal	Use 'Report Suspicious Threat' button on the Community page

Phishing & Social Engineering Knowledge Check

This assessment covers the training content in Part One. On the Nisir Bank SETA Portal, this assessment is automated — select your answer and the system immediately shows whether you are correct or incorrect, and explains why. Your score is recorded and used to standardize security knowledge across all participants before the Internal Mail session begins.

Assessment Details

Questions: 15 | Topics: Phishing types, warning signs, portal security, password rules, reporting culture | Format: Multiple choice | Feedback: Immediate automated feedback per question | Score: Recorded as security knowledge baseline covariate

Question 1 *[Phishing Fundamentals]*

Which of the following best defines a phishing attack in the context of banking?

Op tio n	Answer Choice	Automated Feedback (shown on selection)
A	A software virus that automatically transfers funds from customer accounts.	✗ INCORRECT <i>This describes malware-based financial fraud, not phishing. Phishing specifically targets human behaviour through deceptive communications.</i>
B	A deceptive communication — typically an email — designed to trick an employee into revealing credentials, clicking a malicious link, or submitting sensitive information by impersonating a trusted source.	✓ CORRECT <i>Correct. Phishing exploits human trust and psychology. In a banking environment, attackers impersonate IT departments, regulatory bodies, or colleagues to gain access to systems and customer data.</i>
C	A physical attempt to steal printed documents containing customer account information.	✗ INCORRECT <i>This describes physical document theft. Phishing occurs through digital communications and exploits human psychology, not physical access.</i>
D	An automated system that tests employee passwords for weakness.	✗ INCORRECT <i>This describes a password auditing or brute-force tool. Phishing requires a human to be deceived into taking an action voluntarily.</i>

Question 2 *[Types of Phishing — Spear Phishing]*

You receive an email addressed to you by name, referencing your specific role as a Bank Teller at Nisir Bank, and mentioning a recent internal system update you attended. It asks you to click a link to complete a mandatory compliance step. What type of phishing is this?

Op tio n	Answer Choice	Automated Feedback (shown on selection)
A	Standard phishing — a generic mass email sent to thousands of targets.	✗ INCORRECT <i>Standard phishing uses generic messaging</i>

		without personal details. This email uses your name, role, and recent events — indicating a targeted attack.
B	Spear phishing — a highly targeted attack using personalised information about the specific victim.	✓ CORRECT Correct. Spear phishing uses specific personal, organisational, or contextual details to make the attack appear legitimate. This is the most common and dangerous form of phishing in banking environments because it is very difficult to detect.
C	Vishing — a voice-based phishing attack conducted by phone.	✗ INCORRECT Vishing refers to voice/phone-based social engineering. This scenario involves an email, making it spear phishing.
D	Baiting — using a physical device to lure the victim.	✗ INCORRECT Baiting typically involves physical media such as USB drives left in visible locations. This scenario is a targeted email attack.

Question 3 [Types of Phishing — Internal Impersonation]

An email arrives appearing to come from 'Ato Biruk Alemu — IT Security' using the sender address itsecurity@nisirbank-it.com asking you to verify your portal credentials immediately. What should alert you that this may be fraudulent?

Op tio n	Answer Choice	Automated Feedback (shown on selection)
A	Nothing — the sender name matches the IT Security Officer listed in the staff directory.	✗ INCORRECT Attackers can display any sender name they choose. The sender NAME is not a reliable indicator of authenticity. You must always check the sender EMAIL ADDRESS domain carefully.
B	The sender email domain (nisirbank-it.com) does not match the official bank domain (nisirbank.com) — this is a spoofed address.	✓ CORRECT Correct. Internal impersonation phishing often uses domains that closely resemble the legitimate domain — nisirbank-it.com versus nisirbank.com. Always check the full email address shown under the sender name in your inbox, not just the display name.
C	The email is asking you to verify credentials, which is a normal IT request.	✗ INCORRECT Credential verification via email link is NEVER a legitimate IT request at Nisir Bank. Any email asking you to enter your Employee ID or password via a link is a phishing attack, regardless of who appears to send it.
D	The email uses urgent language, which means it is important and should be actioned immediately.	✗ INCORRECT Urgency is a deliberate manipulation tactic used in phishing attacks to prevent you from thinking carefully. Legitimate bank communications do not require immediate action that bypasses normal security procedures.

Question 4 [Types of Phishing — Regulatory Impersonation]

You receive a professionally formatted email from 'survey@ebca-ethiopia.org' claiming to be from the Ethiopian Banking Compliance Authority (EBCA), requiring

you to complete a mandatory staff awareness survey via an inline link by Friday or your bank's compliance rating will be affected. What is the correct action?

Op tio n	Answer Choice	Automated Feedback (shown on selection)
A	Complete the survey immediately — it is from a regulatory body and non-compliance could affect the bank.	✗ INCORRECT <i>Regulatory impersonation is one of the most effective phishing techniques targeting bank employees. The urgency and threat of regulatory consequences are manipulation tactics. Always verify external regulatory communications through official channels before taking any action.</i>
B	Forward the email to compliance@nisirbank.com for verification before taking any action.	✓ CORRECT <i>Correct. All external communications claiming to be from regulatory bodies must be forwarded to the Compliance Department for verification. Legitimate regulatory communications to individual employees are always coordinated through Nisir Bank's Compliance Department — they are never sent directly to individual staff requiring immediate action via an external link.</i>
C	Click the link but only complete questions that do not ask for personal information.	✗ INCORRECT <i>Clicking an unverified external link is itself a security risk, regardless of what you enter on the resulting page. The click alone can be used to confirm your identity, install tracking software, or expose your device to malware.</i>
D	Search online for the EBCA website and complete the survey from there instead.	✗ INCORRECT <i>While showing good instinct, this is not the correct procedure. Forward the email to the Compliance Department and let them verify whether the survey is legitimate before any staff member takes action.</i>

Question 5 [Types of Phishing — Social and Informal]

You receive an email with the subject 'You Have to See These! Team Day Photos from Last Friday 📸🎉' from 'staffassociation.nisir@gmail.com'. The sender is not in your staff directory. The email contains an inline link to view the photos. What should you do?

Op tio n	Answer Choice	Automated Feedback (shown on selection)
A	Click the link — it is just photos and the content is harmless.	✗ INCORRECT <i>The content of what a phishing link claims to show is irrelevant — what matters is where the link actually leads. Informal social content links are a common low-contextualization phishing technique. The Gmail domain and absence from the staff directory are both warning signs.</i>
B	The sender uses a Gmail address (not @nisirbank.com) and is not on the staff directory. Treat this as suspicious, do not click the link, and report it to the IT Security team.	✓ CORRECT <i>Correct. Social and informal phishing exploits the relaxed vigilance people apply to non-work content. At Nisir Bank, all official staff communications — including event photos and social announcements — come through the official portal or from @nisirbank.com</i>

		addresses. A Gmail sender not on the staff directory is a clear warning sign.
C	Reply to the sender asking them to confirm they work at the bank before clicking.	✗ INCORRECT Replying to a phishing email engages with the attacker and confirms your address is active. Use official internal channels to verify any staff association communications — never the contact details provided in the suspicious email.
D	Forward the email to colleagues to find out if anyone else received it.	✗ INCORRECT Forwarding a potentially malicious email spreads the threat to your colleagues. Report it to the IT Security team at itsecurity@nisirbank.com — not to other employees.

Question 6 [Warning Signs — URL Inspection]

While reading an email in your Nisir Bank SETA Portal inbox, you see an inline link in the body text. Before clicking it, you hover your mouse over the link and the URL displayed at the bottom of your browser shows: <http://nisirbank-secure.login.net/verify>. What does this tell you?

Option	Answer Choice	Automated Feedback (shown on selection)
A	The link is safe because it contains 'nisirbank' in the URL.	✗ INCORRECT Attackers deliberately include the target organisation's name in fake URLs to create false legitimacy. The presence of 'nisirbank' in a URL does not mean it is a Nisir Bank URL. Only URLs using the exact domain nisirbank.com are legitimate.
B	The link is suspicious because the domain (nisirbank-secure.login.net) does not match the official nisirbank.com domain. Do not click it — report the email.	✓ CORRECT Correct. The official Nisir Bank domain is nisirbank.com . Any URL that uses a different domain — even one containing 'nisirbank' as part of a longer string — is fraudulent. Hovering over inline links before clicking to inspect the destination URL is one of the most effective phishing detection techniques available to you.
C	The link is safe because it begins with 'http' which indicates a web address.	✗ INCORRECT The presence of 'http' or even 'https' in a URL does not indicate legitimacy. Attackers routinely use HTTPS on fraudulent sites to appear trustworthy. The domain name is what matters, not the protocol prefix.
D	The link might be safe — the IT department sometimes uses external servers.	✗ INCORRECT Nisir Bank IT systems operate exclusively on the nisirbank.com domain. The IT department does not send links to external servers for credential verification or account management. Any such link is fraudulent.

Question 7 [Warning Signs — Urgency and Threats]

Which of the following email characteristics is a deliberate psychological manipulation technique commonly used in phishing attacks?

Option	Answer Choice	Automated Feedback (shown on selection)
A	The email is addressed to 'Dear Employee' and comes from a verified @nisirbank.com sender.	✗ INCORRECT <i>Generic salutations from verified internal senders are normal bank communications. This is not a phishing indicator — it is standard practice for automated HR and compliance notifications.</i>
B	The email states that your account will be suspended within 24 hours unless you click a link and verify your credentials immediately.	✓ CORRECT <i>Correct. Artificial urgency combined with a threat of negative consequences is one of the most reliable indicators of phishing. Legitimate bank IT processes do not require emergency credential verification via email links within arbitrary timeframes. When you feel pressured to act immediately, slow down and verify through official channels.</i>
C	The email contains an inline link to a training module on the SETA Portal.	✗ INCORRECT <i>Inline links to internal portal pages from verified @nisirbank.com senders are a normal feature of the SETA Portal communication system. Always hover to verify the URL matches nisirbank.com before clicking.</i>
D	The email includes the sender's job title and department below their name.	✗ INCORRECT <i>Professional email signatures with job titles and department information are normal features of legitimate bank communications. Phishing emails may also include professional signatures, so this alone is not a reliable indicator either way.</i>

Question 8 [Correct Response to Suspicious Emails]

You receive an email in your Nisir Bank inbox that you suspect may be phishing. What is the correct complete sequence of actions?

Option	Answer Choice	Automated Feedback (shown on selection)
A	Click the inline link to see where it leads, then report it if the destination page looks suspicious.	✗ INCORRECT <i>Never click a suspicious link to investigate it. Clicking a phishing link can trigger automatic malware downloads, confirm your identity to the attacker, or compromise your device before you even see the page content. Use the hover technique to inspect URLs without clicking.</i>
B	Delete the email immediately to remove the threat from your inbox.	✗ INCORRECT <i>Deleting a phishing email destroys evidence needed by the IT Security team to investigate the attack and warn other employees. Always report before deleting. Preserve the email until IT Security advises you to remove it.</i>
C	Do not click any inline links or download any attachments. Hover over links to check URLs. Report the email to itsecurity@nisirbank.com. If you accidentally interacted with it, report that too immediately — you are protected under the no-blame policy.	✓ CORRECT <i>Correct. This is the complete correct sequence. Reporting suspected phishing — including accidental interactions — is mandatory at Nisir Bank. The no-blame reporting policy explicitly protects employees who report in good faith. Prompt reporting limits damage and protects</i>

		your colleagues.
D	Reply to the email to ask the sender to confirm their identity before taking any action.	✗ INCORRECT <i>Replying to a phishing email directly engages with the attacker, confirms your email address is active, and may provide information the attacker can use. Always verify through official internal channels — never through contact details provided within the suspicious email.</i>

Question 9 [Social Engineering — Pretexting]

You receive a phone call from someone identifying themselves as 'Natnael from IT Support.' They say there is a critical security breach affecting your SETA Portal account and they urgently need your Employee ID and password to secure it before the breach spreads. What should you do?

Option	Answer Choice	Automated Feedback (shown on selection)
A	Provide the information — the caller knows your name and it sounds like a genuine emergency.	✗ INCORRECT <i>This is a classic pretexting attack — a social engineering technique where an attacker creates a fabricated urgent scenario to extract sensitive information. Knowing your name does not verify the caller's identity. Nisir Bank IT staff will NEVER ask for your password through any channel.</i>
B	Provide only your Employee ID but not your password, then change your password immediately afterward.	✗ INCORRECT <i>Your Employee ID should also be protected and not shared over unverified phone calls. Even partial credential sharing can assist an attacker. The correct response is to refuse entirely and report the call.</i>
C	Refuse to provide any credentials, end the call politely, and immediately report the incident to itsecurity@nisirbank.com or Extension 2200.	✓ CORRECT <i>Correct. No legitimate IT support request at Nisir Bank requires you to provide your password verbally or otherwise. Pretexting attacks are designed to bypass your rational thinking through urgency and authority. Refuse, document the call details, and report it immediately — this information helps IT Security identify and stop active attacks.</i>
D	Ask the caller to hold while you contact your line manager for advice.	✗ INCORRECT <i>While involving your manager is a good instinct, the priority is to end the call and report it to IT Security — not to keep an attacker engaged while you seek advice. End the call first, then report.</i>

Question 10 [Password Security — Requirements]

Which of the following passwords meets Nisir Bank's password policy requirements?

Option	Answer Choice	Automated Feedback (shown on selection)
A	NisirBank2024 — includes the organisation name	✗ INCORRECT

	and current year.	<i>This password fails multiple requirements: it does not contain a special character, and it includes the organisation name which is explicitly prohibited. Organisation names and years are highly predictable and easily guessed by attackers.</i>
B	teller01 — easy to remember and related to your job role.	✗ INCORRECT <i>This password fails several requirements: it is only 8 characters (below the 10-character minimum), contains no uppercase letters or special characters, and references your job role which is predictable. Never use job titles, departments, or role names in passwords.</i>
C	Br@nch\$ecure#9 — 14 characters with uppercase, lowercase, numbers, and special characters.	✓ CORRECT <i>Correct. This password meets all Nisir Bank requirements: it exceeds 10 characters, includes uppercase (B, S), lowercase (r, anch, ecur), numbers (9), and special characters (@, \$, #). It does not reference your name, Employee ID, or any predictable personal information.</i>
D	E-10234pass — uses your Employee ID as a memorable base.	✗ INCORRECT <i>Using your Employee ID in your password is explicitly prohibited by the Information Security Policy. Your Employee ID is semi-public information known to multiple staff members, making any password based on it highly vulnerable.</i>

Question 11 [Password Security — Protection Rules]

A senior colleague approaches you and says their computer is broken and they need to urgently submit a compliance report to the Compliance Officer before a regulatory deadline in 30 minutes. They ask to use your computer and your login credentials. What should you do?

Option	Answer Choice	Automated Feedback (shown on selection)
A	Log in for them and step away from the computer to give them privacy.	✗ INCORRECT <i>Sharing your login session — even without sharing your password verbally — is a security policy violation. You remain responsible for all actions taken under your credentials. If something goes wrong during their use of your account, you are accountable.</i>
B	Share your password but stay present to supervise everything they do.	✗ INCORRECT <i>Credential sharing is prohibited under all circumstances regardless of supervision. The mere act of sharing your password violates policy. Your colleague must contact IT Security (Extension 2200) to resolve their access issue — IT can grant temporary access through proper channels.</i>
C	Decline to share your credentials or your session. Direct your colleague to the IT Security helpdesk at Extension 2200 immediately — they can provide emergency access assistance.	✓ CORRECT <i>Correct. Credential sharing is never permissible regardless of urgency, seniority, or justification. The IT Security helpdesk has emergency procedures for exactly this type of situation. Your colleague's urgency is not your</i>

		responsibility to solve by violating security policy.
D	Share your credentials this one time given the regulatory urgency, but report it to IT Security afterward.	✗ INCORRECT Reporting a policy violation you knowingly committed does not retroactively make it permissible. The correct action is always to refuse and direct your colleague to proper channels — not to violate policy and report it afterward.

Question 12 [SETA Portal Security — Credential Rules]

You receive an email in your SETA Portal inbox stating that following a scheduled maintenance, your account needs immediate re-verification. The email contains an inline link saying 'Verify My Account Now' and warns that failure to act within 24 hours will suspend your access. What is the correct response?

Op tio n	Answer Choice	Automated Feedback (shown on selection)
A	Click the inline link and enter your Employee ID and password to restore your access before the deadline.	✗ INCORRECT This is a high-contextualization phishing attack. SETA Portal credential verification is NEVER conducted through email links. The urgency and access suspension threat are phishing manipulation tactics. Clicking this link and entering credentials is a critical security policy violation.
B	Do not click the link. Contact the IT Security helpdesk directly at itsecurity@nisirbank.com or Extension 2200 to verify whether any action is genuinely required, and report the email as suspicious.	✓ CORRECT Correct. The Nisir Bank Information Security Policy and your onboarding documentation explicitly state that SETA Portal credential updates are only ever performed through the IT helpdesk in person or via official helpdesk tickets — never through email links. This email violates that policy and is a phishing attempt.
C	Reply to the email to ask IT Security if the request is genuine.	✗ INCORRECT Replying to a phishing email contacts the attacker, not IT Security. Always use the official IT Security contact details from your staff directory — never contact details provided within the suspicious email itself.
D	Wait 24 hours to see if your access is actually suspended before deciding what to do.	✗ INCORRECT Waiting 24 hours allows a potential attacker ongoing access if other employees clicked the link. Suspected phishing must be reported immediately so the IT Security team can investigate and warn other employees.

Question 13 [Customer Data Protection]

While processing a customer transaction at your branch, you receive an email asking you to confirm a customer's account number and balance by clicking an inline link to an external form. The email appears to come from a partner financial institution. What should you do?

Op tio n	Answer Choice	Automated Feedback (shown on selection)
----------------	---------------	---

A	Complete the form — inter-bank data sharing is part of normal banking operations.	✗ INCORRECT <i>Customer account data sharing must always follow formal inter-bank protocols established through Nisir Bank's legal and compliance channels. Responding to unsolicited email requests to share customer data via external forms — regardless of the apparent sender — is a serious data breach and policy violation.</i>
B	Forward the email to your line manager for approval before responding.	✗ INCORRECT <i>While involving your manager shows good judgment, the correct first step is to forward the email to compliance@nisirbank.com. Customer data requests from external institutions must be verified by the Compliance Department through official channels — not approved informally by line managers.</i>
C	Do not click the link or share any customer information. Forward the email to compliance@nisirbank.com for verification and follow the official inter-bank data request procedures.	✓ CORRECT <i>Correct. Customer account information is protected under Ethiopian financial regulation and Nisir Bank policy. All requests for customer data from external parties must be channelled through the Compliance Department and follow formal inter-bank data sharing protocols. Never share customer data through unsolicited email requests.</i>
D	Click the link to see what information is being requested before deciding whether to share it.	✗ INCORRECT <i>Clicking an unverified external link is a security risk regardless of your intention. The link itself — not just the information you enter — can pose a threat to your device and the bank's network.</i>

Question 14 *[Incident Reporting]*

You realise you clicked an inline link in an email earlier this morning and entered your Employee ID on the page before becoming suspicious. You are worried about getting into trouble. What must you do?

Option	Answer Choice	Automated Feedback (shown on selection)
A	Change your password immediately and hope no damage was done — reporting it may lead to disciplinary action.	✗ INCORRECT <i>Changing your password is a useful first step but is not sufficient on its own. Nisir Bank operates a no-blame reporting policy that explicitly protects employees who report security incidents in good faith. Not reporting a known incident is itself a disciplinary offense — the opposite of what many employees fear.</i>
B	Monitor your account for unusual activity over the next few days and only report if something seems wrong.	✗ INCORRECT <i>Delayed reporting allows attackers more time to exploit compromised credentials. In banking environments, even minutes of unauthorized access can cause significant harm. Immediate reporting is mandatory — not optional.</i>
C	Report immediately to itsecurity@nisirbank.com and your line manager. Explain exactly what happened and follow IT Security's instructions. You are protected under the no-blame reporting policy.	✓ CORRECT <i>Correct. Prompt reporting is your most important obligation after a potential security incident. The no-blame policy means you will not face disciplinary action for reporting in good faith. IT Security can immediately take</i>

		protective action — including credential reset and access monitoring — that can contain any damage. The longer you wait, the greater the potential harm.
D	Ask a trusted colleague what they think you should do before reporting.	✗ INCORRECT Consulting a colleague delays the IT Security response. Report directly and immediately to itsecurity@nisirbank.com or call Extension 2200. Do not involve non-IT staff in security incident response.

Question 15 [No-Blame Reporting Culture]

Which of the following statements about Nisir Bank's incident reporting culture is correct?

Option	Answer Choice	Automated Feedback (shown on selection)
A	Employees who accidentally click phishing links face automatic disciplinary action regardless of how quickly they report it.	✗ INCORRECT This is incorrect. Nisir Bank operates an explicit no-blame reporting culture. Employees who report security incidents in good faith — including accidental interactions with phishing content — are protected from disciplinary action. The bank recognises that human error is inevitable and that prompt reporting is more valuable than concealment.
B	Employees only need to report security incidents if they believe customer data has been compromised.	✗ INCORRECT All suspected security incidents must be reported immediately, regardless of whether customer data was involved. Even a suspected phishing attempt that caused no apparent damage must be reported so IT Security can investigate and protect other employees.
C	Employees who knowingly fail to report a security incident they are aware of may face disciplinary action under the bank's Code of Conduct — but employees who report incidents in good faith are protected.	✓ CORRECT Correct. The no-blame policy creates an asymmetry: reporting is protected and encouraged; concealment is a disciplinary offense. This design is intentional — it creates an environment where employees feel safe coming forward immediately, which is essential for effective security incident management in a bank.
D	Only IT Security staff are responsible for reporting security incidents — other employees should focus on their core banking tasks.	✗ INCORRECT Every employee at Nisir Bank has a personal obligation to report security incidents. Information security is not solely the IT department's responsibility — the bank's defence against attacks depends on all staff actively participating in threat identification and reporting.

Assessment complete. Your score has been recorded. You may now proceed to the Internal Mail inbox.

Nisir Bank S.C. | Security Operations Team | itsecurity@nisirbank.com | Extension 2200